

[PE 86.2] Entrega Proyecto — TechSecure



TechSecure: Informe de Seguridad y Control de Accesos

Analista: Xavier Margalef Riestra

Fecha: 2026-06-03

Módulo: MF0486_3

Clasificación: Entregable Oficial / Evaluación

Actividad 1 - Matriz de accesos

Principio de Mínimo Privilegio = [PoLP que se engloba dentro del modelo Zero Trust](#)

Me adhiero a la nomenclatura del enfoque/modelo/framework Zero Trust 2.0 IAM para realizar el ejercicio:

- **FC** (Full Control)
- **RW** (Read/Write)
- **RO** (Read Only)
- **NA** (No Access)

Tabla:

Recurso / Activo	Departamento: Administración	Departamento: Ventas	Departamento: Soporte Técnico
Acceso a Internet	RW (Controlado para limitar y bloquear páginas y softwares para evitar descuidos)	RW (idem)	RW (Total debido a la necesidad de hacer operaciones en red)
Correo electrónico	RW (Canal de comunicación básico para toda la empresa)	RW (idem)	RW (idem)
Sistema de impresión	RW (idem)	RW (idem)	RW (idem)
Base de datos Contabilidad	RW (Lo necesita para cumplir su función y rol)	NA (No requiere)	NA (idem)
Base de datos Clientes	RO (Requiere leer pero realmente no editan clientes)	RW (Requieren editar porque suman clientes en ventas)	RO (Necesitan leer para consulta de usuarios con SQL)
Servidores y sistemas	NA (No impacta a su función)	NA (idem)	RW (Requiere para gestionar sobretodo sistemas, el FC sería para DevOps/SRE)
Configuración de red	NA	NA	RW (Requiere para gestionar sobretodo configuraciones dadas por ing. sistemas)
Logs y auditoría	RO (Acceso para investigar no representa peligro y ayuda a su función)	NA (El retorno de que puedan leer no supone beneficio)	FC (Encargados junto a Ciberseguridad de establecer sistemas de trazabilidad de la información)

Actividad 2 - Accesos no controlados

- **¿Cuál es la amenaza principal?**

El **acceso y edición incontrolado** de los empleados a cualquier subsistema crítico, afectando directamente a la base de datos de producción de información financiera.

- **¿Qué vulnerabilidad permitió este incidente?**

La **ausencia de una política de control de accesos** y la falta de un modelo de mínimo privilegio (**PoLP**). La carencia de una gestión **IAM** impide que ciberseguridad aplique bloqueos automáticos según las funciones y roles de cada usuario.

- **¿Qué tipo de salvaguarda sería más efectiva para prevenirlo? Técnica, Administrativa o Física**

- **Administrativa (Principal):** Es la principal porque el fallo es de seguridad de la información. Exige definir una estrategia bajo **Zero Trust 2.0** que ordene los permisos de la empresa.
- **Técnica:** Implementar un control **IAM** restrictivo basado en roles para bloquear por completo los accesos lógicos no autorizados a nivel de base de datos.
- **Física:** Controlar de forma presencial el acceso a los espacios comunes e infraestructura de servidores mediante tarjetas de acceso o videovigilancia.

- **¿Cómo aplicarías el ciclo PDCA para resolver este problema?**

- **Plan:** Diseñar la política **Zero Trust** mapeando los roles de los empleados para determinar que Ventas tiene denegación explícita (**NA**) a los esquemas de finanzas.
- **Do:** Aplicar **contenciones rápidas** directas en la red y grupos de usuarios (restricciones inmediatas y bloqueos de red a las instancias de la base de datos).
- **Check:** Entrar en fase de **monitorización continua**, haciendo auditorías de vulnerabilidades y revisando los logs para vigilar los intentos de acceso denegados.
- **Act:** Analizar el incidente técnico (**postmortem**), evaluar el impacto real que tuvo la negligencia del usuario (*insider threat* involuntario) y retroalimentar el Plan.

- **¿Cómo clasificarías este incidente: Seguridad de la Información, Ciberseguridad o Seguridad Informática?**

Es un problema de **Seguridad de la Información**. No existió una intrusión externa ni malware, sino un fallo estructural en el diseño de los accesos (*Security by Design*) que permitió a un usuario del personal alterar registros críticos.

- **Evalúa el riesgo en términos de impacto y probabilidad:**

- **Fórmula:** $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$
- **Impacto: Alto.** Afecta de forma directa a la integridad del activo financiero de la empresa, pudiendo provocar descuadres económicos y problemas legales.
- **Probabilidad: Alta.** Al no existir restricciones técnicas ni bloqueos aplicados, cualquier usuario puede volver a equivocarse en cualquier momento.
- **Riesgo Total: Crítico**

Actividad 3 - Conexión de dispositivos no autorizados

- **¿Cuál es la amenaza principal?**

El **malware** activo alojado en el equipo del trabajador que actúa como un vector de ataque interno.

- **¿Qué vulnerabilidad fue explotada?**

La **falta de control perimetral** de la red interna y la ausencia de herramientas que limiten o bloqueen hardware ajeno. El punto débil es la falta de defensas como un sistema de control de accesos de red, cortafuegos internos o soluciones **EDR**.

- **¿Qué tipo de salvaguardas deben implementarse? Técnica, Administrativa o Física**

- **Técnica (Principal):** Corregir la arquitectura tecnológica desplegando herramientas preventivas de ciberseguridad como soluciones **AV/EDR** y segmentación por **VLANs** para aislar el tráfico.
- **Administrativa:** Redactar una política corporativa estricta que prohíba de manera explícita la conexión de ordenadores personales a las redes privadas de producción.
- **Física:** Bloquear y deshabilitar los puertos físicos que estén libres en las oficinas para evitar que pinchen cables de red sin autorización.

- **¿Cómo aplicarías el ciclo PDCA en este caso?**

- **Plan:** Planificar el despliegue del sistema **EDR** corporativo y revisar las directrices y permisos de red asignados a cada grupo de usuarios.
- **Do:** Ejecutar las medidas de contingencia: **aislar el dispositivo de ventas** infectado para frenar la propagación, limpiar los sistemas y levantar cortafuegos perimetrales.
- **Check:** Realizar una **monitorización continua** del tráfico interno de datos para verificar que el rendimiento vuelve a la normalidad y descartar que el malware siga activo.
- **Act:** Realizar la auditoría **postmortem** de la infección para aplicar las lecciones aprendidas, actualizando las firmas de los sistemas de defensa.

- **¿Es un problema de Seguridad de la Información, Ciberseguridad o Seguridad Informática?**

Es un incidente de **Ciberseguridad**. La disponibilidad y el rendimiento de la infraestructura técnica se vieron atacados por un código malicioso, provocado originalmente por una deficiencia en la política de **Seguridad de la Información** que no controló los accesos a la red.

- **Evalúa el riesgo en términos de impacto y probabilidad:**

- **Fórmula:** $\text{Riesgo} = \text{Impacto} \times \text{Probabilidad}$
- **Impacto: Alto.** Provoca la ralentización y degradación de los servicios críticos, deteniendo la actividad operativa normal de la empresa.
- **Probabilidad: Media.** La conexión de hardware no controlado por parte de empleados ocurre con frecuencia si no hay campañas previas de concienciación (*security awareness*).
- **Riesgo Total: Alto**